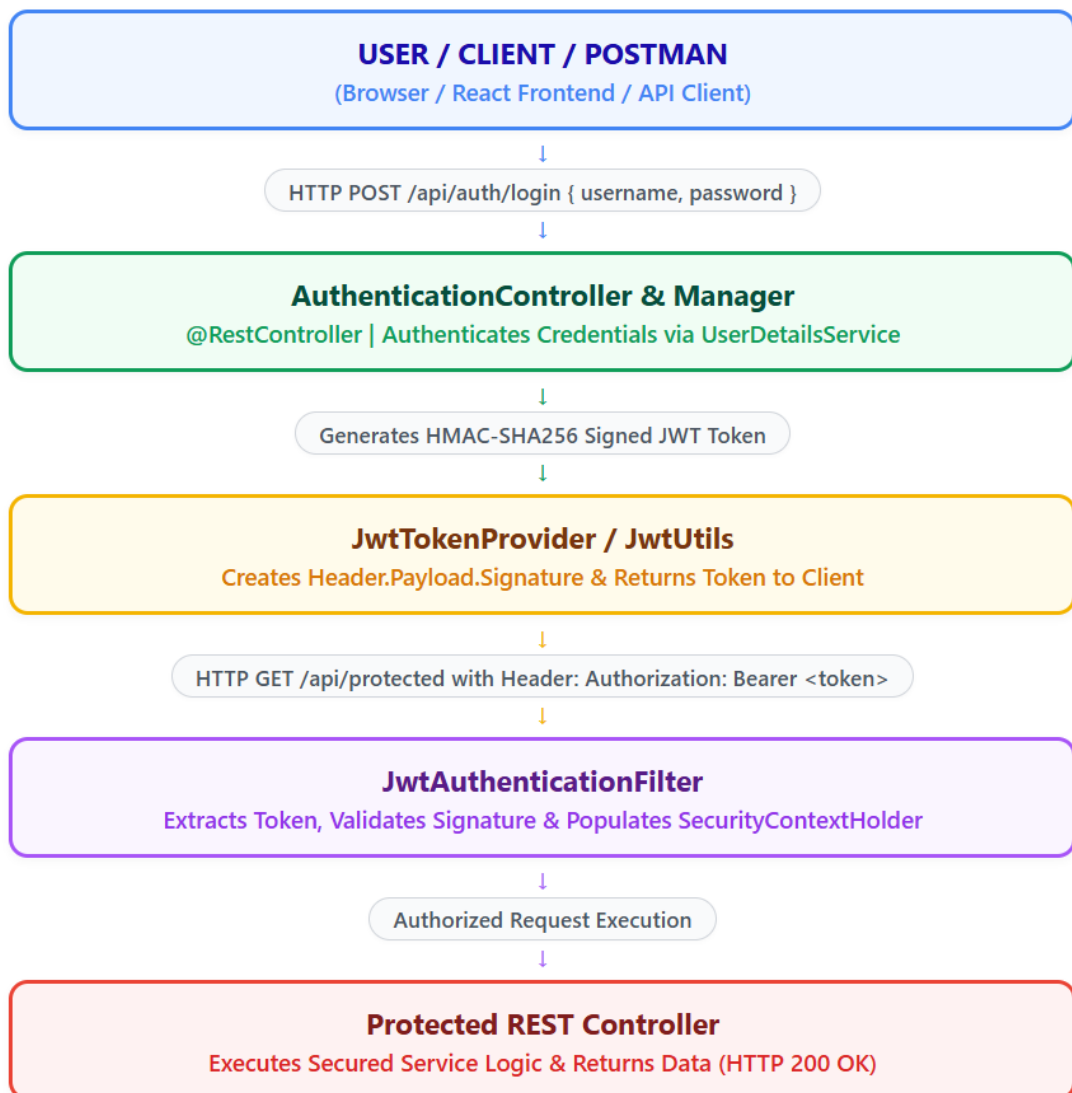


EXPERIMENT NO. 06**AIM**

Implement JWT authentication in a Spring Boot application.

LEARNING OUTCOMES

Integrate front-end and back-end with secure API endpoints.

THEORY

JSON

- A JSON Web Token (JWT) is an open, industry-standard (RFC 7519) method for representing claims securely between two parties. In modern web architectures, JWT is widely used for stateless authentication and authorization, eliminating the need for server-side HTTP sessions.

Structure of a JWT

- A JSON Web Token consists of three distinct parts separated by dots (.):

Header.Payload.Signature

- **Header** - The header contains metadata about the token, including the signature algorithm used (e.g., HMAC SHA256 or RSA) and the token type (JWT).

JSON

```
{
  "alg": "HS256",
  "typ": "JWT"
}
```

- **Payload** - The payload contains claims—statements about an entity (typically the user) and additional metadata. Claims fall into three categories:
 - **Registered claims:** Predefined standard claims such as sub (subject), iat (issued at), exp (expiration time), and iss (issuer).
 - **Public claims:** Custom claims defined by applications, collision-resistant when following URI conventions.
 - **Private claims:** Custom fields agreed upon between parties (e.g., role, email).

JSON

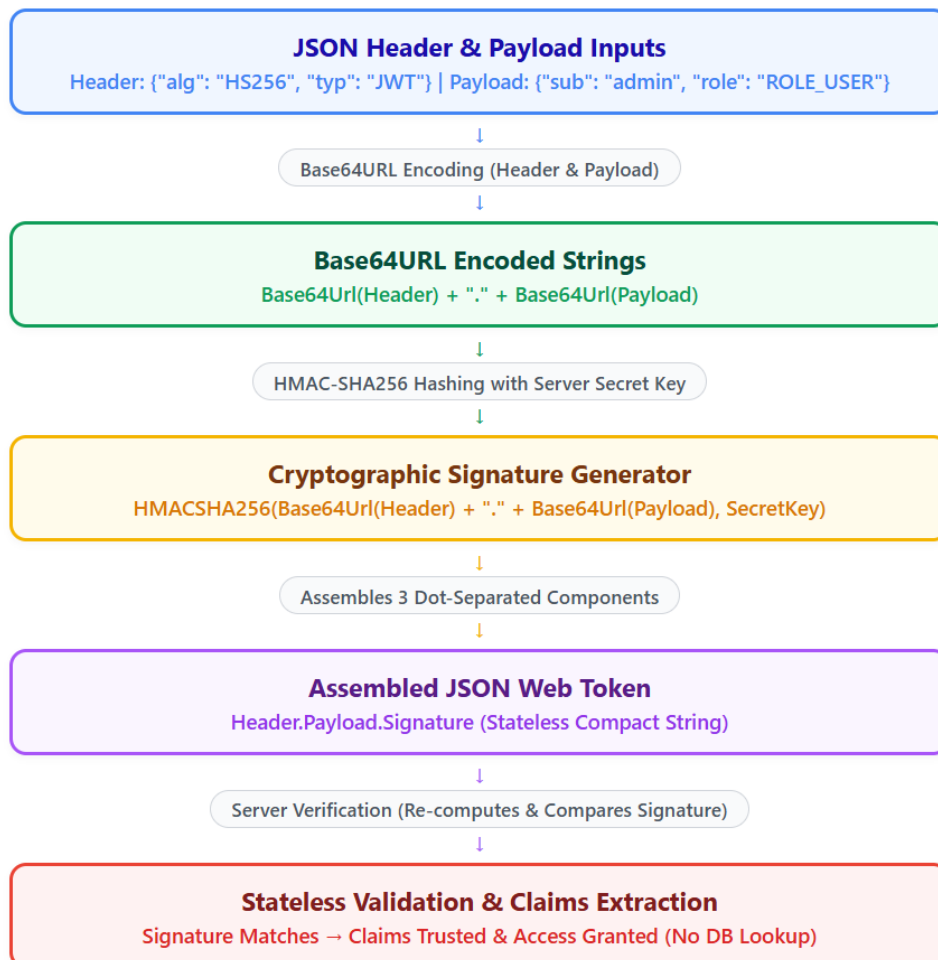
```
{
  "sub": "admin",
  "role": "ROLE_USER",
  "iat": 1726963200,
  "exp": 1727049600
}
```

- **Signature** - The signature verifies that the message was not altered along the way. It is calculated by taking the Base64Url-encoded header and payload, combining them with a secret key, and signing them using the specified algorithm:

```
HMACSHA256(
  base64UrlEncode(header) + "." + base64UrlEncode(payload),
  secretKey
)
```

JWT Authentication Flow

- JWT authentication follows a stateless request-response lifecycle:



Detailed Step-by-Step Mechanism

- Authentication Request:** The client submits login credentials (username and password) via HTTP POST.
- Credential Validation:** The server verifies the credentials against its backend store (e.g., database or `UserDetailsService`).
- Token Creation:** If valid, the server creates a JWT containing the user's identity and permissions, signs it with a private key/secret, and returns it in the HTTP response body or header.
- Token Storage:** The client saves the token (typically in memory or secure storage).
- Subsequent API Requests:** For any access to restricted routes, the client includes the token in the standard HTTP request header:

Authorization: Bearer <your_jwt_token_here>

- **Token Verification:** A server-side interceptor/filter (`JwtAuthenticationFilter`) intercepts the request, strips the `Bearer` prefix, and verifies the token's signature using the secret key. If valid and not expired, the user context is loaded into `SecurityContextHolder`.
- **Resource Access:** The request proceeds to the controller and executes the underlying business logic.

Key Concepts & Annotations

- **JSON Web Token (JWT):** A compact, URL-safe means of representing claims to be transferred between two parties. It consists of three parts: Header, Payload (Subject, Expiration), and Signature
- **OncePerRequestFilter:** A Spring Security base class guaranteeing a single execution per request dispatch, ideal for parsing and validating incoming Authorization headers
- **SecurityFilterChain:** The core bean in Spring Security 6+ configuring route permissions (`permitAll()`, `authenticated()`), session policy (`STATELESS`), and filter insertion.
- **AuthenticationManager:** The primary API for processing authentication requests in Spring Security.
- **BCryptPasswordEncoder:** Secure hashing implementation used for encoding stored passwords.

OUTPUT

.....

.....

.....

1. Why is session management set to `SessionCreationPolicy.STATELESS` when using JWT?
2. What is the purpose of the Bearer prefix in the HTTP Authorization header?
3. How does `BCryptPasswordEncoder` contribute to security in Spring Security?

[illegible]

This image shows a full page of white paper with horizontal dotted lines, typical of primary school writing paper. The lines are evenly spaced and run across the width of the page. There are no margins, text, or other markings on the paper.

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

ASSESSMENT SCHEME

Performance Indicator	Max. Marks	Marks Obtained
Understanding	5	
Implementation	7	
Timely Submission	3	
Total	15	

Signature of Faculty with Date